CENTRO UNIVERSITÁRIO DE LINS - UNILINS
CURSO DE ENGENHARIA DE SOFTWARE

LUCAS MORENO RODRIGUES

PROTEÇÃO DE DADOS PESSOAIS EM APIS DE DOCUMENTOS DIGITAIS: APLICAÇÃO DA LGPD, PROGRAMAÇÃO SEGURA E CRIPTOGRAFIA

LINS
2026

LUCAS MORENO RODRIGUES

PROTEÇÃO DE DADOS PESSOAIS EM APIS DE DOCUMENTOS DIGITAIS: APLICAÇÃO DA LGPD, PROGRAMAÇÃO SEGURA E CRIPTOGRAFIA

Relatório final de Iniciação Científica apresentado ao Centro Universitário de Lins - UNILINS, Pró-Reitoria de Pesquisa - NuPe, no âmbito do Programa de Iniciação Científica 2025/2026, como parte das atividades do curso de Engenharia de Software.

Orientador: Prof. Dr. João Luís Cardoso de Moraes

LINS
2026

LUCAS MORENO RODRIGUES

PROTEÇÃO DE DADOS PESSOAIS EM APIS DE DOCUMENTOS DIGITAIS: APLICAÇÃO DA LGPD, PROGRAMAÇÃO SEGURA E CRIPTOGRAFIA

Relatório final de Iniciação Científica apresentado ao Centro Universitário de Lins - UNILINS, Pró-Reitoria de Pesquisa - NuPe, no âmbito do Programa de Iniciação Científica 2025/2026, como parte das atividades do curso de Engenharia de Software.

Aprovado em: ____ de _____ de 2026.

_____
Prof. Dr. João Luís Cardoso de Moraes - Orientador

_____
Membro da banca examinadora

_____
Membro da banca examinadora

RESUMO

Aplicações que recebem documentos digitais tratam arquivos capazes de conter dados pessoais, metadados e informações sigilosas, o que exige medidas de segurança durante transmissão, processamento, armazenamento e descarte. Este trabalho analisa o protótipo DigitalSign, composto por backend Spring Boot e frontend React, como estudo de caso para investigar de que modo criptografia e programação segura podem reduzir riscos de exposição de dados e contribuir para os princípios da Lei Geral de Proteção de Dados Pessoais (LGPD). A pesquisa teve inicialmente como foco a assinatura digital; entretanto, a evolução do protótipo para incluir cadastro de usuários, autenticação JWT, persistência em PostgreSQL, auditoria e verificação pública ampliou o conjunto de operações de tratamento. Por essa razão, o título foi alterado para refletir a proteção do ciclo de vida dos dados como tema central, mantendo a assinatura digital como um dos controles estudados. A metodologia reuniu análise documental, inspeção técnica previamente registrada do repositório, inventário de dados, modelagem qualitativa de ameaças, matriz de rastreabilidade e consolidação de testes existentes. Os resultados indicam controles já presentes, como BCrypt, JWT, RBAC, limite de upload, hashes SHA-256 e assinatura SHA256withRSA, mas também lacunas: ausência de TLS comprovado, inexistência de criptografia em repouso, validação de PDF baseada principalmente em Content-Type, segredos de desenvolvimento versionados, retenção indefinida e exposição excessiva de dados no PDF e no navegador. Conclui-se que a criptografia é indispensável para confidencialidade, integridade e autenticidade, porém não assegura conformidade isoladamente. Sua eficácia depende de gestão de chaves, minimização, controle de acesso, validação de entradas, logs seguros, retenção limitada, testes e governança.

Palavras-chave: LGPD; criptografia; programação segura; API; documentos digitais; assinatura digital.

ABSTRACT

Applications that receive digital documents process files that may contain personal data, metadata, and confidential information, requiring security measures during transmission, processing, storage, and disposal. This study analyzes the DigitalSign prototype, composed of a Spring Boot backend and a React frontend, as a case study to investigate how cryptography and secure programming can reduce data exposure risks and support the principles of the Brazilian General Data Protection Law (LGPD). The research initially focused on digital signatures; however, the prototype evolved to include user registration, JWT authentication, PostgreSQL persistence, audit trails, and public verification, expanding the number of personal-data processing operations. Therefore, the title was changed to reflect data lifecycle protection as the central topic while retaining digital signatures as one of the controls under study. The methodology combined document analysis, a previously recorded technical inspection of the repository, data inventory, qualitative threat modeling, traceability, and consolidation of existing tests. Results show controls such as BCrypt, JWT, RBAC, upload limits, SHA-256 hashes, and SHA256withRSA signatures, as well as relevant gaps: no demonstrated TLS configuration, no encryption at rest, PDF validation mainly based on Content-Type, versioned development secrets, undefined retention, and excessive exposure of personal data in the PDF and browser. The study concludes that cryptography is essential for confidentiality, integrity, and authenticity, but does not provide compliance by itself. Its effectiveness depends on key management, minimization, access control, input validation, secure logging, limited retention, testing, and governance.

Keywords: LGPD; cryptography; secure programming; API; digital documents; digital signature.

LISTA DE ABREVIATURAS E SIGLAS

AES - Advanced Encryption Standard
API - Application Programming Interface
ASVS - Application Security Verification Standard
HMAC - Hash-based Message Authentication Code
HSM - Hardware Security Module
ICP-Brasil - Infraestrutura de Chaves Públicas Brasileira
JWT - JSON Web Token
LGPD - Lei Geral de Proteção de Dados Pessoais
PDF - Portable Document Format
PKI - Public Key Infrastructure
RBAC - Role-Based Access Control
RSA - Rivest-Shamir-Adleman
SHA - Secure Hash Algorithm
TLS - Transport Layer Security

SUMÁRIO

1 INTRODUÇÃO **7**
1.1 Delimitação e problema de pesquisa 8
1.2 Justificativa da alteração do título 8
1.3 Organização do trabalho 9
2 OBJETIVOS **10**
2.1 Objetivo geral 10
2.2 Objetivos específicos 10
3 FUNDAMENTAÇÃO TEÓRICA **11**
3.1 LGPD, dados pessoais e segurança desde a concepção 11
3.2 Propriedades de segurança da informação 11
3.3 Mecanismos criptográficos e funções distintas 12
3.4 TLS, criptografia em repouso e gestão de chaves 13
3.5 Assinatura digital, PKI e o contexto brasileiro 14
3.6 Programação segura em APIs de documentos 15
4 TRABALHOS RELACIONADOS E EVOLUÇÃO DO PROJETO **16**
4.1 Trabalho relacionado 16
4.2 Da prova de conceito ao estado documentado 16
5 METODOLOGIA **17**
5.1 Fontes analisadas 17
5.2 Etapas do estudo 17
5.3 Evidências, critérios e cuidados éticos 18
6 ARQUITETURA E CICLO DE VIDA DOS DADOS **19**
6.1 Tecnologias e módulos 19
6.2 Fluxo de assinatura e verificação 19
6.3 Dados pessoais e locais de permanência 20
6.4 Estado dos mecanismos criptográficos 21
7 RESULTADOS E ANÁLISE DE RISCOS **22**
7.1 Controles observados 22
7.2 Lacunas relevantes 22
7.3 Matriz qualitativa de riscos 23
7.4 Testes e evidências existentes 23
8 DISCUSSÃO: CRIPTOGRAFIA, PROGRAMAÇÃO SEGURA E LGPD **24**
8.1 Como a criptografia pode proteger o ciclo de vida 24
8.2 Relação entre princípios da LGPD e controles técnicos 24
8.3 Limites da criptografia como medida de conformidade 25
8.4 Contribuição do novo recorte 25
9 PLANO DE EVOLUÇÃO E VALIDAÇÃO **26**
9.1 Prioridade P0 - riscos imediatos 26
9.2 Prioridade P1 - prevenção e prestação de contas 26
9.3 Prioridade P2 - controles estruturais 26
9.4 Casos de teste recomendados 27
10 LIMITAÇÕES **28**
11 CONCLUSÃO **29**
REFERÊNCIAS **30**
APÊNDICE A - MATRIZ DE RASTREABILIDADE **31**

1 INTRODUÇÃO

A digitalização de processos administrativos, acadêmicos, empresariais e jurídicos ampliou o uso de APIs para receber, transformar, assinar, verificar e devolver documentos eletrônicos. Arquivos PDF podem conter nome, CPF, endereço, dados financeiros, informações de saúde, assinaturas, anexos e metadados capazes de identificar pessoas. Assim, o processamento de um documento não constitui apenas uma operação técnica sobre bytes: ele integra um ciclo de tratamento de dados pessoais que precisa ser conhecido, limitado e protegido.

A Lei nº 13.709/2018 define tratamento de maneira ampla, abrangendo coleta, recepção, utilização, acesso, processamento, armazenamento, comunicação e eliminação. A mesma lei determina que as atividades observem princípios como finalidade, adequação, necessidade, transparência, segurança, prevenção e responsabilização, além de exigir medidas técnicas e administrativas desde a concepção do produto ou serviço (Brasil, 2018). Para uma API de documentos digitais, esses deveres alcançam o upload, o tráfego de rede, a memória do servidor, o banco de dados, os logs, os backups e o arquivo devolvido ao usuário.

A criptografia contribui para esse cenário ao oferecer propriedades distintas. O TLS protege dados durante a comunicação; a criptografia simétrica pode reduzir a inteligibilidade de dados armazenados; hashes apoiam a detecção de alterações; assinaturas digitais relacionam integridade e autenticidade à posse de uma chave privada; mecanismos como HMAC protegem a integridade de tokens. Essas funções, embora complementares, não são equivalentes. Assinar um PDF não o torna confidencial, calcular seu hash não impede leitura e criptografar um banco não corrige uma autorização incorreta.

O protótipo DigitalSign foi inicialmente apresentado como uma demonstração de assinatura digital em memória, composta por backend Spring Boot e frontend React. A evolução registrada na documentação técnica passou a incluir cadastro de usuários, autenticação JWT, persistência JPA em PostgreSQL, trilhas de auditoria, administração por papéis e verificação pública por código e QR Code. Essa mudança aumentou a quantidade de dados pessoais coletados, os locais de permanência e as superfícies de ataque, tornando necessária uma análise que ultrapassasse a estrutura criptográfica da assinatura.

1.1 Delimitação e problema de pesquisa

O objeto prático permanece sendo a API DigitalSign e seu fluxo de processamento de PDFs. O estudo, porém, não busca certificar juridicamente o sistema, comprovar conformidade integral com a LGPD ou afirmar que a assinatura atual possui cadeia ICP-Brasil. O recorte consiste em analisar o ciclo de vida dos dados pessoais, os controles de programação segura e o papel da criptografia na redução de riscos observáveis no protótipo.

A pergunta de pesquisa adotada é: como a aplicação coordenada de práticas de programação segura e mecanismos criptográficos pode reduzir riscos de vazamento de dados pessoais durante o processamento de documentos PDF por uma API?

1.2 Justificativa da alteração do título

O título original, “Assinatura Digital e Proteção de Dados: Convergência com a Lei Geral de Proteção de Dados (LGPD)”, colocava a assinatura digital no centro da investigação. Esse recorte foi adequado à primeira etapa, na qual a prova de conceito buscava demonstrar a geração de uma assinatura em PDF e a comunicação entre frontend e backend. O relatório parcial também registrou a evolução do mecanismo de QR Code e da página de verificação.

A análise posterior evidenciou, contudo, que assinatura digital e proteção de dados não são sinônimos. A assinatura contribui principalmente para integridade e autenticidade técnica; não impede a leitura do conteúdo, não protege automaticamente o tráfego de rede, não define quem pode acessar registros, não limita a coleta, não estabelece prazo de retenção e não evita que logs revelem informações pessoais. Além disso, a versão atual do protótipo passou a persistir dados e a expor novos fluxos de autenticação, verificação e administração.

Diante dessa ampliação, adotou-se o título “Proteção de dados pessoais em APIs de documentos digitais: aplicação da LGPD, programação segura e criptografia”. A alteração representa um refinamento do problema científico, e não a substituição do projeto. A API e a assinatura continuam como estudo de caso, mas a análise passa a considerar defesa em profundidade, minimização, validação de arquivos, proteção de segredos, logs seguros, retenção e descarte, criptografia em trânsito e em repouso e gestão de chaves.

A mudança também aumenta a coerência entre título, metodologia e evidências. Em vez de presumir que um mecanismo criptográfico produz conformidade, o novo recorte permite verificar quais controles existem, quais estão ausentes e como cada medida se relaciona com

riscos e princípios da LGPD. Essa formulação é mais conveniente para o estágio atual do protótipo e oferece base para evoluções técnicas mensuráveis.

1.3 Organização do trabalho

Após esta introdução, apresentam-se objetivos, fundamentação teórica, trabalhos relacionados, metodologia, arquitetura e ciclo de dados, resultados, discussão, plano de evolução, limitações e conclusão. O apêndice reúne uma matriz resumida de rastreabilidade entre requisitos, estado observado e evidências futuras.

2 OBJETIVOS

2.1 Objetivo geral

Analisar práticas de desenvolvimento seguro e mecanismos criptográficos aplicáveis a uma API de documentos digitais, demonstrando como controles de acesso, minimização, validação de arquivos, proteção de chaves, criptografia, assinatura digital e descarte seguro podem reduzir riscos de vazamento e contribuir para os princípios de segurança, prevenção, necessidade e responsabilização previstos na LGPD.

2.2 Objetivos específicos

- Identificar os dados pessoais e ativos tratados no cadastro, envio, processamento, assinatura, verificação e administração.
- Mapear os locais de processamento e permanência dos dados e as respectivas fronteiras de confiança.
- Diferenciar criptografia de conteúdo, TLS, hash, assinatura digital, HMAC e hashing de senhas.
- Avaliar controles de autenticação, autorização, validação de uploads, tratamento de erros, logs e segredos.
- Identificar ameaças e classificar qualitativamente riscos relacionados à confidencialidade, integridade e disponibilidade.
- Relacionar controles e lacunas aos princípios da LGPD e às medidas de segurança previstas nos arts. 46 e 49.
- Consolidar os testes já executados e propor casos negativos capazes de produzir evidências antes e depois das melhorias.
- Definir um plano priorizado de implementação sem apresentar funcionalidades planejadas como resultados concluídos.
- Esclarecer os limites da assinatura atual, especialmente a ausência de certificado X.509 confiável e de cadeia ICP-Brasil.

3 FUNDAMENTAÇÃO TEÓRICA

3.1 LGPD, dados pessoais e segurança desde a concepção

A LGPD considera dado pessoal a informação relacionada a pessoa natural identificada ou identificável. No protótipo, nome, e-mail, telefone, CPF, data de nascimento, endereço IP e user-agent podem se enquadrar nessa definição. O CPF é dado pessoal e identificador relevante, mas não integra por si só a lista legal de dados pessoais sensíveis do art. 5º, II. Ainda assim, sua exposição pode aumentar riscos de fraude e associação indevida, justificando minimização e proteção proporcional.

O art. 6º estabelece dez princípios: finalidade, adequação, necessidade, livre acesso, qualidade dos dados, transparência, segurança, prevenção, não discriminação e responsabilização e prestação de contas. Em uma API, esses princípios podem ser traduzidos em perguntas verificáveis: cada campo é necessário? o usuário compreende onde seus dados aparecerão? um documento de outro usuário pode ser acessado? logs armazenam conteúdo excessivo? os registros possuem prazo de retenção? as medidas adotadas podem ser demonstradas por testes?

O art. 46 exige medidas técnicas e administrativas contra acessos não autorizados e situações acidentais ou ilícitas, determinando que a segurança seja observada desde a concepção até a execução. O art. 49 acrescenta que sistemas de tratamento devem ser estruturados conforme requisitos de segurança, boas práticas, governança e princípios gerais. Portanto, desenvolvimento seguro e proteção de dados devem integrar requisitos, arquitetura, implementação, testes e operação, e não ser adicionados apenas ao final (Brasil, 2018).

A criptografia pode contribuir diretamente para tornar dados ininteligíveis a terceiros não autorizados, inclusive como fator considerado na avaliação de incidentes. Todavia, a lei não prescreve um algoritmo único nem reduz segurança à criptografia. Natureza dos dados, finalidade, volume, contexto, probabilidade e impacto orientam a escolha de salvaguardas técnicas e administrativas.

3.2 Propriedades de segurança da informação

Confidencialidade limita o acesso ao conteúdo; integridade permite detectar alterações indevidas; autenticidade sustenta a verificação da origem ou identidade; disponibilidade mantém o serviço acessível quando necessário. Uma assinatura digital pode apoiar integridade

e autenticidade, mas não garante disponibilidade. A criptografia de um arquivo protege confidencialidade apenas enquanto a chave permanece inacessível a terceiros não autorizados.

O não repúdio é frequentemente associado a assinaturas digitais, mas depende de condições adicionais: identificação confiável do titular, controle exclusivo da chave privada, políticas de emissão, revogação, carimbo de tempo, preservação de evidências e contexto jurídico. No protótipo, a chave efêmera sem certificado confiável permite demonstrar a operação matemática, mas não sustenta, sozinha, uma afirmação de não repúdio ou validade ICP-Brasil.

3.3 Mecanismos criptográficos e funções distintas

Criptografia simétrica utiliza uma chave secreta para cifrar e decifrar dados e é adequada a grandes volumes. O AES é um padrão amplamente adotado, mas sua segurança depende do modo de operação, geração de nonce ou vetor de inicialização, autenticação, tamanho de chave e gestão do material criptográfico (NIST, 2023). Em armazenamento, pode ser aplicada ao volume, banco, colunas, objetos, PDFs ou backups; cada nível apresenta impactos diferentes sobre pesquisa, indexação, recuperação e rotação de chaves.

Criptografia assimétrica utiliza par de chaves pública e privada. Ela é empregada em troca de chaves, certificados e assinaturas, mas não deve ser confundida com a cifragem direta de todo o documento. Sistemas reais frequentemente combinam técnicas em criptografia de envelope: dados são cifrados por chave simétrica e essa chave é protegida por mecanismo assimétrico ou serviço de gestão de chaves.

Funções de hash produzem um resumo de tamanho fixo. A comparação de hashes permite detectar alterações, mas o hash não oculta o documento nem possibilita recuperar seu conteúdo. Para senhas, uma função rápida como SHA-256 isolada é inadequada; utilizam-se algoritmos de derivação resistentes a tentativas em massa, com salt e custo configurável. O protótipo adota BCrypt para novos cadastros e migra um formato legado baseado em SHA-256 durante o login.

Quadro 1 - Propriedades e limitações dos mecanismos criptográficos

Mecanismo	Contribuição principal	Não garante isoladamente
HTTPS/TLS	Confidencialidade e integridade dos dados em trânsito; autenticação do servidor.	Proteção do banco, autorização por objeto ou retenção.
Criptografia em repouso	Redução da inteligibilidade de banco, volume, arquivos e backups sem a chave.	Segurança quando a aplicação já está autorizada a decifrar; minimização.

Mecanismo	Contribuição principal	Não garante isoladamente
Hash SHA-256	Detecção de alteração por comparação de resumos.	Confidencialidade, autoria ou armazenamento seguro de senha.
Assinatura digital	Integridade e autenticidade vinculadas à chave privada.	Sigilo do PDF, validade jurídica automática ou disponibilidade.
HMAC/JWT assinado	Integridade e autenticidade do token conforme segredo ou chave.	Revogação, armazenamento seguro no navegador ou autorização correta.
BCrypt	Proteção de senhas armazenadas por salt e custo de processamento.	Rate limiting, MFA ou proteção da sessão.

Fonte: elaborado pelo autor (2026).

3.4 TLS, criptografia em repouso e gestão de chaves

O TLS 1.3 define um protocolo para impedir escuta, adulteração e falsificação de mensagens na rede, utilizando criptografia autenticada e negociação de chaves (Rescorla, 2018). Em uma API, HTTPS deve abranger login, upload, download, verificação e rotas administrativas. O fato de o ambiente local operar por HTTP pode ser aceitável em desenvolvimento isolado, mas a publicação externa requer terminação TLS comprovada no proxy ou na infraestrutura.

A criptografia em repouso deve incluir a análise de bancos, volumes, arquivos temporários, backups e exportações. Cifrar o disco reduz impacto de perda física ou acesso ao volume desligado, mas não impede que uma conta de banco comprometida leia dados por meio da aplicação. A cifragem de campos pode reduzir exposição de colunas específicas, porém aumenta complexidade de busca, indexação e rotação. A decisão precisa partir do modelo de ameaça e da necessidade do dado.

A gestão de chaves compreende geração com fonte aleatória adequada, armazenamento protegido, controle de acesso, uso auditável, rotação, revogação, backup e destruição. Chaves e segredos não devem residir no código-fonte ou em arquivos versionados. Recomendações do NIST destacam que políticas, responsabilidades e proteção ao longo do ciclo de vida são tão importantes quanto o algoritmo (Barker, 2020). Para protótipos, variáveis de ambiente e arquivos locais não versionados são o mínimo; ambientes reais podem exigir cofre de segredos, KMS ou HSM.

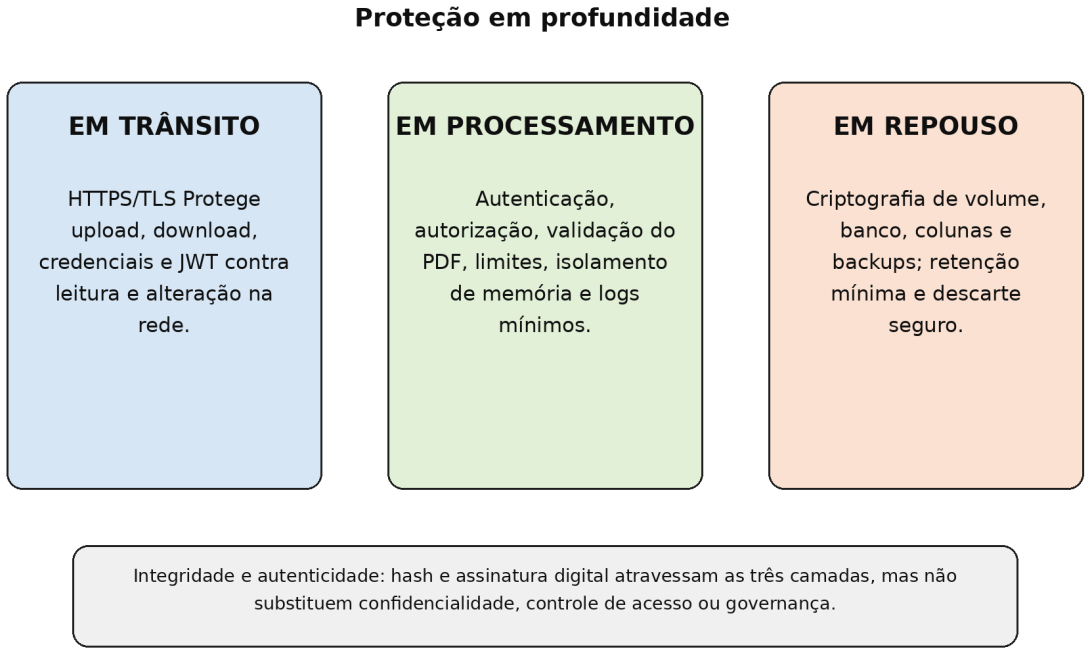


Figura 1 - Camadas complementares de proteção de dados em uma API
Fonte: elaborado pelo autor (2026).

3.5 Assinatura digital, PKI e o contexto brasileiro

Na assinatura digital, o documento participa de uma operação de hash e o resultado é assinado com a chave privada; a verificação utiliza a chave pública correspondente. A descrição popular de "criptografar o hash com a chave privada" é didática, mas simplifica formatos, preenchimentos, identificadores de algoritmo e estruturas de assinatura.

A Medida Provisória nº 2.200-2/2001 instituiu a ICP-Brasil e estabeleceu presunção de veracidade para declarações produzidas com processo de certificação nela disponibilizado, sem impedir outros meios de comprovação de autoria e integridade aceitos pelas partes (Brasil, 2001). Certificado X.509, cadeia de confiança, proteção da chave, revogação e políticas da autoridade certificadora são elementos essenciais quando se pretende associar a assinatura a uma identidade juridicamente verificável.

No DigitalSign, a documentação registra RSA 2048 e SHA256withRSA, com chave gerada em memória por assinatura e sem certificado X.509 persistido, keystore ou cadeia ICP-Brasil. O Adobe Acrobat pode reconhecer a estrutura de assinatura do PDF, mas a confiança na identidade depende do certificado e da cadeia. Assim, o resultado deve ser apresentado como demonstração técnica de assinatura, não como assinatura qualificada ou presumidamente válida pela ICP-Brasil.

3.6 Programação segura em APIs de documentos

A segurança de upload não deve confiar em extensão ou Content-Type informado pelo cliente. A OWASP recomenda lista de extensões permitidas, validação do tipo real, nomes controlados, limite de tamanho, autenticação, autorização, armazenamento seguro e, quando aplicável, antivírus, sandbox ou reconstrução do conteúdo (OWASP Foundation, 2026). Para PDFs, o parse controlado precisa rejeitar arquivos corrompidos, estruturas excessivas e recursos incompatíveis com o caso de uso.

Autenticação responde quem é o usuário; autorização decide o que ele pode fazer. APIs devem negar acesso por padrão, validar papel e propriedade do objeto a cada requisição e evitar que a simples troca de identificador permita consultar dados de outra pessoa. O ASVS 5.0.0 fornece requisitos verificáveis para arquitetura, validação, autenticação, autorização, tokens, criptografia, logs e configuração, sendo apropriado para transformar boas práticas em casos de teste (OWASP Foundation, 2025).

Logs devem registrar o necessário para auditoria sem duplicar dados pessoais ou segredos. Conteúdo de PDF, senha, token, chave privada e CPF completo não devem aparecer em mensagens operacionais. Erros enviados ao cliente precisam ser genéricos o suficiente para não revelar stack traces, caminhos, consultas ou configurações, enquanto os detalhes internos permanecem protegidos e correlacionáveis.

Retenção limitada e descarte seguro reduzem o período de exposição. Processar o PDF em memória evita a persistência automática do arquivo, mas não elimina cópias em buffers, cache, swap, dumps ou logs. O projeto precisa documentar o que permanece, por quanto tempo, por qual finalidade e como ocorre eliminação ou anonimização.

4 TRABALHOS RELACIONADOS E EVOLUÇÃO DO PROJETO

4.1 Trabalho relacionado

Abreu Teotonio (2012) apresentou uma API Java para geração de assinaturas digitais conforme regulamentações da ICP-Brasil. O trabalho contribui para compreender certificados, formatos e operações criptográficas associados à assinatura. O presente estudo diferencia-se ao utilizar uma aplicação Spring Boot/React como estudo de caso para o ciclo de vida de dados pessoais, incluindo autenticação, persistência, auditoria, ameaças de API e princípios da LGPD.

4.2 Da prova de conceito ao estado documentado

A proposta de 2025 descrevia backend simplificado, sem banco de dados, processamento em memória e frontend preliminar. O relatório parcial de março de 2026 registrou a adição de QR Code, link de verificação e estudos de adequação à LGPD. A análise técnica de agosto de 2026 identificou uma aplicação mais ampla, com persistência e controles de acesso. A comparação demonstra por que os riscos e objetivos precisaram ser atualizados.

Quadro 2 - Evolução do escopo entre a proposta e o estado documentado

Aspecto	Proposta inicial	Estado documentado em 2026
Persistência	Sem banco; operações em memória.	JPA com PostgreSQL no perfil principal e H2 em testes.
Usuários	Fluxo experimental.	Cadastro, login, BCrypt, JWT, papéis USER e ADMIN.
Verificação	Validação básica da assinatura.	Código público, QR Code, página de verificação e confirmação de identidade.
Auditoria	Planejada.	Tabela de audit_logs e rotas administrativas de consulta/exportação.
Dados pessoais	Tratamento descrito genericamente.	Nome, e-mail, telefone, CPF, nascimento, IP, user-agent e metadados.
Segurança	Múltiplos controles prometidos.	Parte implementada; TLS, repouso, retenção e validação robusta ainda não comprovados.

Fonte: elaborado pelo autor a partir da proposta, do relatório parcial e da documentação técnica (2026).

5 METODOLOGIA

A pesquisa possui natureza aplicada e caráter exploratório e descritivo, utilizando o protótipo DigitalSign como estudo de caso tecnológico. O método combina revisão de fontes normativas e técnicas com análise documental e avaliação de segurança registrada no repositório. A finalidade é compreender o problema, documentar o estado existente e propor controles verificáveis, sem realizar auditoria jurídica de conformidade.

5.1 Fontes analisadas

Foram utilizados a proposta original do PIC, o relatório parcial, o manual de apresentação de trabalhos acadêmicos da UNILINS e doze arquivos de documentação técnica produzidos a partir da inspeção do projeto. Esses arquivos abrangem estado da API, ciclo de vida de dados, programação segura, criptografia, ameaças, rastreabilidade, plano de implementação, testes, conteúdo-base, referências e diário de evidências.

A fundamentação foi confrontada com a LGPD compilada, a Medida Provisória nº 2.200-2/2001, orientação da ANPD, padrões do NIST, RFC 8446 e materiais oficiais da OWASP, Spring e Apache. Quando a documentação do repositório não comprovou uma funcionalidade, o relatório a classificou como ausente, não comprovada, parcial ou proposta.

5.2 Etapas do estudo

1. Análise da proposta e do relatório parcial para identificar objetivos, premissas e alterações históricas.
2. Consolidação da inspeção estática registrada de controllers, services, modelos, repositórios, configurações, frontend, containers e testes.
3. Inventário dos dados, operações de tratamento, locais de permanência, compartilhamentos e lacunas de retenção.
4. Separação conceitual entre assinatura digital, hash, criptografia de conteúdo, TLS, hashing de senha e autenticação/autorização.
5. Modelagem qualitativa de ameaças por ativo, vulnerabilidade, impacto, probabilidade e severidade, sem pontuação quantitativa devido à ausência de métricas operacionais.
6. Mapeamento de controles e riscos aos princípios e artigos de segurança da LGPD.

7. Consolidação de testes existentes e definição de casos negativos e critérios de aceite para melhorias futuras.
8. Elaboração de plano P0, P1 e P2 e de matriz de rastreabilidade para o relatório final.

5.3 Evidências, critérios e cuidados éticos

As evidências existentes incluem resultados de testes Maven e npm, lint, build, inventário de dependências e referências a classes e configurações. Os testes propostos devem utilizar exclusivamente PDFs sintéticos e dados fictícios. Nenhum nome, CPF, e-mail ou documento real deve ser inserido em casos de segurança, capturas ou anexos.

A classificação de risco é relativa ao protótipo e não equivale a teste de invasão. Ausência de código visível para um controle não prova que ele inexista em infraestrutura externa; por isso, TLS e criptografia de volume são descritos como não comprovados no escopo analisado.

6 ARQUITETURA E CICLO DE VIDA DOS DADOS

6.1 Tecnologias e módulos

O backend documentado utiliza Java 17, Spring Boot 3.5.0, Spring Security, Spring Data JPA, PDFBox 2.0.30, Bouncy Castle e ZXing. O frontend utiliza React, Vite, TypeScript e Axios. O perfil principal persiste dados em PostgreSQL; testes utilizam H2. Containers organizam banco, backend e frontend servido por Nginx.

Quadro 3 - Componentes tecnológicos do protótipo

Componente	Tecnologia	Função no tratamento
Frontend	React/Vite/TypeScript/Axios	Cadastro, login, upload, verificação, administração e armazenamento local do token.
API	Java 17/Spring Boot	Recepção, regras, assinatura, hashing, auditoria e respostas HTTP.
Segurança	Spring Security/JWT/BCrypt	Autenticação, autorização por papel e proteção de senhas.
PDF	PDFBox/Bouncy Castle	Leitura, metadados, página adicional e assinatura SHA256withRSA.
Persistência	JPA/PostgreSQL	Usuários, registros de assinatura e logs de auditoria.
Verificação	ZXing/QR Code	Criação de link para consulta pública do registro.

Fonte: elaborado pelo autor (2026).

6.2 Fluxo de assinatura e verificação

O usuário autenticado envia um PDF por multipart com JWT. O backend rejeita ausência ou vazio, compara o Content-Type com application/pdf e aplica limite de 10 MB. Em seguida, carrega o arquivo em memória, gera código de verificação, QR Code e par RSA, adiciona dados do signatário e assina o documento. Hashes do PDF original e assinado e metadados pessoais são persistidos, enquanto o PDF completo é devolvido ao navegador e não foi observado em armazenamento permanente da aplicação.

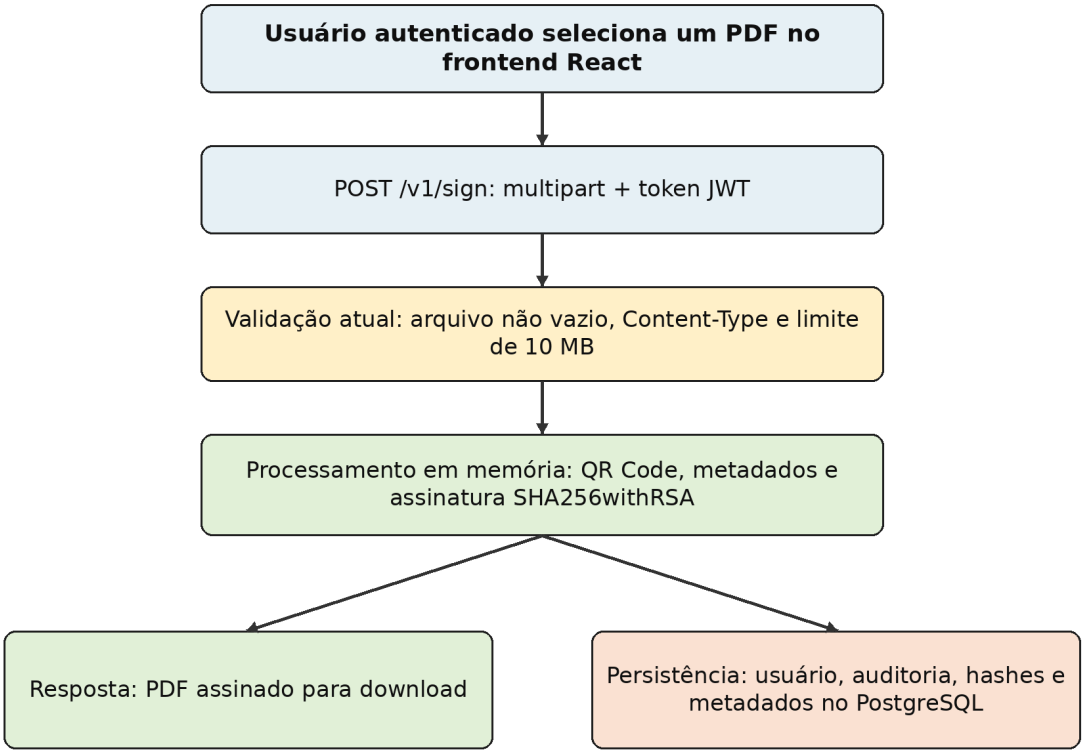


Figura 2 - Fluxo documentado de tratamento do PDF no DigitalSign
Fonte: elaborado pelo autor a partir de 01-estado-atual-da-api.md (2026).

6.3 Dados pessoais e locais de permanência

O cadastro recebe nome, e-mail, telefone, CPF, data de nascimento e senha. Registros de assinatura também armazenam código, usuário, nome, e-mail, CPF, data, IP, user-agent, hashes e informações de revogação. Logs registram ator, evento, resultado, alvo, IP, user-agent e detalhes. O PDF final recebe nome, e-mail e CPF em página adicional e metadados. O frontend mantém JWT e dados do usuário em localStorage.

Quadro 4 - Inventário resumido de dados e riscos

Dado/ativo	Local	Proteção observada	Lacuna principal
Nome/e-mail/CPF	Usuários, assinaturas e PDF	RBAC em rotas privadas; máscara parcial em algumas respostas.	Exposição no PDF/verificação e retenção indefinida.
Telefone/nascimento	Tabela de usuários	Não retornados nas respostas analisadas.	Necessidade técnica não demonstrada.
Senha	Hash no banco	BCrypt para novos cadastros.	Sem rate limiting ou política de senha documentada.

Dado/ativo	Local	Proteção observada	Lacuna principal
JWT	localStorage e cabeçalho	Assinatura HMAC e expiração.	Exposição a XSS; segredo de desenvolvimento versionado.
PDF original/assinado	Memória e download	Autenticação, limite e hash.	Validação fraca; PDF final não cifrado.
IP/user-agent	Assinaturas e auditoria	Acesso administrativo.	Finalidade e retenção não formalizadas.
Logs/CSVs	Banco e exportação	RBAC ADMIN.	Possível concentração e exfiltração de dados em massa.

Fonte: elaborado pelo autor (2026).

6.4 Estado dos mecanismos criptográficos

A assinatura PDF usa SHA256withRSA e par RSA 2048 gerado em memória por requisição. O sistema calcula SHA-256 dos arquivos original e assinado. JWT utiliza HMAC com segredo configurável e expiração; senhas novas são armazenadas com BCrypt. Não foram comprovados TLS no Spring, Compose ou Nginx, criptografia de colunas ou volume, criptografia do PDF final, certificado X.509 persistido ou cadeia ICP-Brasil.

7 RESULTADOS E ANÁLISE DE RISCOS

7.1 Controles observados

O protótipo demonstra que segurança já foi incorporada parcialmente à arquitetura. Rotas de assinatura exigem autenticação, rotas administrativas exigem papel ADMIN, senhas novas usam BCrypt, uploads possuem limite, registros de auditoria são persistidos e respostas de verificação mascaram o CPF em determinados pontos. Hashes e assinatura oferecem evidências de integridade técnica.

- Autenticação por JWT e filtro Spring Security.
- RBAC para o namespace administrativo.
- BCrypt e migração de hash legado no login.
- Limite multipart de 10 MB.
- Assinatura SHA256withRSA, QR Code e hashes dos PDFs.
- Auditoria persistida e exportações restritas a ADMIN.
- Testes automatizados básicos de backend e frontend.

7.2 Lacunas relevantes

Os controles não cobrem todo o ciclo. A configuração analisada usa HTTP, a validação confia principalmente no Content-Type, dados persistidos não possuem criptografia em repouso comprovada, segredos de desenvolvimento aparecem em configurações versionadas, o código público é UUID truncado, rotas futuras podem ficar públicas por anyRequest().permitAll(), dados não possuem prazo de retenção e o frontend armazena token e CPF em localStorage.

A página final do PDF inclui CPF completo, nome e e-mail. A verificação pública expõe informações e permite confirmação por CPF/e-mail sem rate limiting documentado. Esses recursos podem ser funcionais, mas exigem análise de finalidade, minimização, entropia do código, respostas menos informativas e controles contra enumeração.

7.3 Matriz qualitativa de riscos

Quadro 5 - Riscos prioritários identificados

ID	Ameaça	Probabilidade	Severidade	Tratamento prioritário
R1	Interceptação de PDF, senha ou JWT em trânsito	Média	Alta	HTTPS/TLS comprovado.
R2	Upload falso, corrompido ou malicioso	Alta	Alta	Validação real, parse controlado e testes negativos.
R3	Uso indevido de segredo versionado	Média	Crítica	Rotação, remoção do repositório e cofre/variáveis seguras.
R4	Retenção excessiva de dados e logs	Alta	Alta	Política, anonimização e expurgo.
R5	Enumeração da verificação pública	Média	Alta	Token forte, rate limiting e resposta mínima.
R6	Acesso indevido ao banco ou volume	Média	Alta	Segredos fortes e criptografia em repouso/backups.
R7	Roubo de JWT por XSS/localStorage	Média	Média	Redução de dados locais, CSP e sessão mais segura.
R8	Exposição de CPF no PDF final	Alta	Média	Mascaramento ou justificativa explícita e opção configurável.
R9	DoS por memória e CPU	Média	Alta	Limites, timeout, rate limiting e processamento controlado.

Fonte: elaborado pelo autor a partir de 05-modelagem-ameacas-e-riscos.md (2026).

7.4 Testes e evidências existentes

O diário de evidências registra execução em 7 de agosto de 2026. Os resultados confirmam funcionamento básico e qualidade de build, mas não substituem testes de segurança. O inventário Maven não constitui varredura de vulnerabilidades, e o npm audit representa apenas a base e o momento em que foi executado.

Quadro 6 - Evidências técnicas consolidadas

Comando	Resultado	Interpretação
mvn test	5 testes; 0 falhas	Backend funcional no conjunto existente; houve warning de cache do PDFBox.
npm test	3 testes; sucesso	Frontend passou após contornar limitação ambiental de spawn.
npm run lint	Sucesso	Sem erros de lint reportados.
npm run build	Sucesso	Bundle Vite gerado.
npm audit --audit-level=high	0 vulnerabilidades	Resultado limitado às dependências npm e à base consultada.
mvn dependency:tree	Sucesso	Inventário de dependências; não é scanner de vulnerabilidade.

Fonte: diário de evidências da análise técnica (2026).

8 DISCUSSÃO: CRIPTOGRAFIA, PROGRAMAÇÃO SEGURA E LGPD

8.1 Como a criptografia pode proteger o ciclo de vida

No tráfego, HTTPS/TLS deve proteger credenciais, JWT, PDF e respostas contra observação e alteração. A aplicação também precisa validar o certificado do servidor e evitar conteúdo misto. No processamento, a criptografia não substitui autenticação e autorização: o backend precisa decidir se o usuário pode executar a operação, reduzir cópias na memória e limitar tamanho e tempo.

Em repouso, dados do PostgreSQL, volumes, dumps, backups e exportações podem ser cifrados. Para campos de maior risco, criptografia de aplicação pode ser avaliada, desde que chaves permaneçam separadas e que rotação, indexação e recuperação sejam planejadas. O PDF final pode ser criptografado quando a finalidade exigir confidencialidade após o download; entretanto, a gestão da senha ou chave de abertura passa a ser um novo problema e não deve ocorrer pelo mesmo canal sem proteção adicional.

Para integridade, o hash permite comparar versões, e a assinatura registra uma operação verificável pela chave pública. A versão atual, porém, não conserva certificado confiável ou cadeia duradoura, de modo que a assinatura deve ser entendida como demonstração. Uma evolução para PKI real exigiria identidade verificada, armazenamento protegido da chave, certificado, revogação, política de assinatura e validação independente.

8.2 Relação entre princípios da LGPD e controles técnicos

Quadro 7 - Aplicação de princípios da LGPD ao protótipo

Princípio	Aplicação técnica	Evidência necessária
Finalidade/adequação	Justificar cada dado e cada exposição no PDF/verificação.	Inventário aprovado e aviso de privacidade.
Necessidade	Remover telefone/nascimento sem uso; reduzir CPF no PDF e localStorage.	Teste de respostas, metadados e armazenamento local.
Livre acesso/qualidade	Permitir consulta e correção dentro do papel institucional aplicável.	Fluxo documentado ou endpoint/processo testado.
Transparência	Informar dados coletados, retenção, auditoria e verificação pública.	Aviso claro na interface e documentação.
Segurança	TLS, RBAC, criptografia em repouso, gestão de segredos e validação.	Configurações e testes negativos.
Prevenção	Rate limiting, scanner de dependências, logs seguros e modelagem de ameaças.	Relatórios, alertas e diário de evidências.

Princípio	Aplicação técnica	Evidência necessária
Responsabilização	Manter registros de decisões, testes, incidentes e descarte.	Matriz de rastreabilidade e evidências reproduzíveis.

Fonte: elaborado pelo autor (2026).

8.3 Limites da criptografia como medida de conformidade

Criptografia reduz consequências de determinados acessos indevidos, mas não corrige coleta excessiva, finalidade incompatível, base legal ausente, falta de transparência ou retenção indefinida. Dados decifrados pela aplicação permanecem expostos a autorizações incorretas, contas comprometidas, injeções, logs ou exportações. Chaves armazenadas junto aos dados podem anular o benefício esperado.

Também não se deve cifrar indiscriminadamente sem considerar disponibilidade e recuperação. Perder a chave pode tornar dados legítimos inacessíveis; uma rotação mal executada pode interromper o serviço; backups sem chave recuperável podem ser inúteis. Segurança requer equilíbrio entre confidencialidade, integridade, disponibilidade, rastreabilidade e direitos dos titulares.

8.4 Contribuição do novo recorte

O novo título permite estudar criptografia de maneira mais completa: não apenas a operação de assinatura, mas a proteção do transporte, do armazenamento, das credenciais e das chaves. Ao mesmo tempo, aproxima a pesquisa da programação segura, porque demonstra que as garantias dependem da interação entre código, configuração, infraestrutura e governança.

Essa mudança torna os resultados mais honestos e úteis. Controles presentes são reconhecidos; lacunas são declaradas; recomendações são priorizadas; e a conformidade não é presumida. A API torna-se um laboratório para avaliar proteção de dados por evidências comparáveis antes e depois de cada melhoria.

9 PLANO DE EVOLUÇÃO E VALIDAÇÃO

9.1 Prioridade P0 - riscos imediatos

- Remover e rotacionar segredos operacionais versionados; manter somente exemplo sem valores sensíveis.
- Configurar ou documentar a terminação obrigatória de HTTPS/TLS e comprovar a negociação em ambiente de teste.
- Implementar validação robusta do PDF, incluindo assinatura do formato, parse controlado, corrupção, tipo real e limite.
- Trocar liberação genérica de rotas por autenticação ou negação por padrão.
- Reduzir CPF e outros dados no PDF, metadados, respostas e localStorage.

9.2 Prioridade P1 - prevenção e prestação de contas

- Aplicar rate limiting em login, verificação e assinatura.
- Padronizar erros e mascarar dados em logs e auditoria.
- Definir política de retenção e job de expurgo ou anonimização.
- Ampliar testes de autenticação, autorização, upload, logs e descarte.
- Adicionar varredura de dependências e segredos ao processo de integração contínua.

9.3 Prioridade P2 - controles estruturais

- Avaliar criptografia de volume, banco, campos e backups conforme o modelo de ameaça.
- Definir fluxo aplicável de consulta, correção e eliminação de dados do titular.
- Avaliar PKI e certificado real caso a finalidade exija identidade verificável e validade externa.
- Implementar monitoramento, alertas e resposta a incidentes com papéis e evidências.

9.4 Casos de teste recomendados

Quadro 8 - Testes de segurança e critérios de aceite

Teste	Resultado esperado	Evidência
PDF falso/corrompido	400 padronizado, sem stack trace.	Teste automatizado com bytes sintéticos.
Arquivo acima do limite	413 ou erro definido sem esgotar recursos.	Teste de limite controlado.
Assinatura sem JWT	401/403.	MockMvc ou chamada HTTP.
USER em rota ADMIN	403.	Teste de RBAC.
Enumeração pública	Rate limit e resposta mínima.	Sequência controlada de tentativas.
Logs	Ausência de CPF, senha, token e conteúdo do PDF.	Consulta aos logs com dados fictícios.
TLS	Certificado e protocolo negociados.	Saída de cliente TLS e configuração.
Retenção	Registros expirados removidos ou anonimizados.	Teste com datas simuladas.
Antes/depois	Risco reproduzível deixa de ocorrer após controle.	Diário, commit e resultados equivalentes.

Fonte: elaborado pelo autor (2026).

Os itens P0, P1 e P2 constituem plano de evolução. Eles não devem ser descritos como implementados até que código, configuração e testes forneçam evidências. Cada mudança precisa atualizar a matriz de rastreabilidade e o diário de evidências.

10 LIMITAÇÕES

- A análise técnica reflete a documentação da working tree de 7 de agosto de 2026, com alterações não commitadas; versões posteriores podem divergir.
- Não foi validado um ambiente de produção nem foi possível confirmar TLS ou criptografia providos externamente pela infraestrutura.
- Não foram utilizados documentos reais, testes de invasão ou dados pessoais verdadeiros.
- O npm audit não cobre o ecossistema Maven; dependency:tree é inventário, não varredura de vulnerabilidades.
- A assinatura não foi validada como ICP-Brasil nem com certificado X.509 confiável no Adobe Acrobat.
- A classificação de riscos é qualitativa e não utiliza histórico de incidentes, volume real ou métricas de produção.
- O relatório oferece análise acadêmica e técnica, não parecer jurídico de conformidade com a LGPD.

11 CONCLUSÃO

O estudo demonstrou que uma API de documentos digitais trata dados pessoais em múltiplas etapas e que a segurança precisa acompanhar todo o ciclo de vida. A evolução do DigitalSign ampliou funcionalidades e superfícies de risco, justificando a alteração do título para um recorte centrado em proteção de dados, programação segura e criptografia. A assinatura digital permanece relevante, mas passa a ocupar seu papel correto dentro de uma estratégia de defesa em profundidade.

Os mecanismos encontrados fornecem uma base acadêmica consistente: BCrypt reduz a exposição de senhas, JWT e RBAC controlam parte dos acessos, hashes apoiam integridade, a assinatura SHA256withRSA demonstra autenticidade técnica, o limite de upload restringe consumo e a auditoria oferece rastreabilidade. Os testes existentes confirmam funcionamento básico do backend e frontend.

Persistem, contudo, lacunas que impedem afirmar proteção completa ou conformidade: TLS não comprovado, ausência de criptografia em repouso, validação insuficiente do PDF, segredos de desenvolvimento versionados, retenção indefinida, código público reduzido, falta de rate limiting e exposição de dados no PDF e no navegador. A assinatura atual também não possui cadeia de certificado confiável e não deve ser apresentada como ICP-Brasil.

A resposta ao problema de pesquisa é que criptografia e programação segura reduzem riscos quando aplicadas de forma coordenada. TLS protege trânsito; criptografia em repouso protege mídias, bancos e backups dentro de seu modelo de ameaça; hash e assinatura detectam alterações; gestão de chaves sustenta essas garantias; e controles de acesso, minimização, validação, logs, retenção e testes impedem que a proteção seja anulada por falhas de aplicação ou governança.

Conclui-se que a criptografia é necessária, mas não suficiente. A contribuição principal do trabalho é transformar princípios abstratos da LGPD em riscos, controles e evidências técnicas verificáveis no contexto de uma API real. O plano proposto fornece caminho incremental para que o protótipo evolua com maior segurança e transparência, mantendo distinção clara entre resultado observado, recomendação futura e conformidade jurídica.

REFERÊNCIAS

ABREU TEOTONIO, Cleverson. Implementação de uma API Java de geração de assinaturas digitais de acordo com as regulamentações da ICP-Brasil. 2012. Monografia (Bacharelado em Ciência da Computação) - Centro Universitário Eurípides de Marília, Marília, 2012. Disponível em: https://aberto.univem.edu.br/handle/11077/863. Acesso em: 10 ago. 2026.

APACHE SOFTWARE FOUNDATION. Apache PDFBox: a Java PDF library. [S. l.], 2026. Disponível em: https://pdfbox.apache.org/. Acesso em: 10 ago. 2026.

AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS. Guia orientativo sobre segurança da informação para agentes de tratamento de pequeno porte. Brasília, DF: ANPD, 2021. Disponível em: https://www.gov.br/anpd/pt-br/centrais-de-conteudo/materiais-educativos-e-publicacoes/guia-vf.pdf. Acesso em: 10 ago. 2026.

BARKER, Elaine. Recommendation for key management: part 1 - general. Revision 5. Gaithersburg: National Institute of Standards and Technology, 2020. (NIST Special Publication 800-57 Part 1 Rev. 5). Disponível em: https://doi.org/10.6028/NIST.SP.800-57pt1r5. Acesso em: 10 ago. 2026.

BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/l13709compilado.htm. Acesso em: 10 ago. 2026.

BRASIL. Medida Provisória nº 2.200-2, de 24 de agosto de 2001. Institui a Infraestrutura de Chaves Públicas Brasileira - ICP-Brasil. Brasília, DF: Presidência da República, 2001. Disponível em: https://www.planalto.gov.br/ccivil_03/mpv/antigas_2001/2200-2.htm. Acesso em: 10 ago. 2026.

NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. Advanced Encryption Standard (AES). Updated 1. Gaithersburg: NIST, 2023. (FIPS PUB 197). Disponível em: https://doi.org/10.6028/NIST.FIPS.197-upd1. Acesso em: 10 ago. 2026.

OWASP FOUNDATION. OWASP API Security Top 10 - 2023. [S. l.], 2023. Disponível em: https://owasp.org/API-Security/editions/2023/en/0x11-t10/. Acesso em: 10 ago. 2026.

OWASP FOUNDATION. OWASP Application Security Verification Standard 5.0.0. [S. l.], 2025. Disponível em: https://owasp.org/www-project-application-security-verification-standard/. Acesso em: 10 ago. 2026.

OWASP FOUNDATION. File Upload Cheat Sheet. [S. l.], 2026. Disponível em: https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html. Acesso em: 10 ago. 2026.

RESCORLA, Eric. The Transport Layer Security (TLS) Protocol Version 1.3. [S. l.]: Internet Engineering Task Force, 2018. (RFC 8446). Disponível em: https://doi.org/10.17487/RFC8446. Acesso em: 10 ago. 2026.

SPRING. Spring Security reference. [S. l.], 2026. Disponível em: https://docs.spring.io/spring-security/reference/. Acesso em: 10 ago. 2026.

APÊNDICE A - MATRIZ DE RASTREABILIDADE

A matriz a seguir separa o estado observado de ações ainda planejadas e indica a evidência necessária antes que um controle seja apresentado como implementado.

Quadro 9 - Rastreabilidade entre tema, estado e evidência

Tema	Estado documentado	Próxima ação	Evidência para conclusão
HTTPS/TLS	Não comprovado	Configurar proxy/infraestrutura.	Configuração e teste TLS.
Criptografia em repouso	Não observada	Selecionar camada e gestão de chaves.	Teste de volume/dump sem chave.
Hash dos PDFs	Parcial	Criar comparação verificável.	Teste com PDF alterado.
Assinatura/PKI	Demonstração sem cadeia	Manter limitação ou integrar certificado real.	Validação da cadeia e política.
JWT	Implementado parcialmente	Proteger segredo e avaliar revogação/sessão.	Teste de expiração/revogação.
RBAC	USER/ADMIN	Negar por padrão e testar papéis.	Testes 401/403.
Validação de PDF	Content-Type e vazio	Adicionar tipo real, parse e corrupção.	Suite de arquivos sintéticos.
Logs/auditoria	Parcial	Mascarar e definir retenção.	Teste de ausência de dados indevidos.
Retenção/descarte	Não implementado	Definir política e job.	Teste de registros expirados.
Monitoramento	Health/info	Criar métricas e alertas.	Simulação de evento e alerta.

Fonte: elaborado pelo autor a partir de 06-matriz-rastreabilidade-pic.md (2026).